ICS/OT/IoT Threat Model

Siemens SIMATIC PCS 7 Process Control System (DCS)

Generated 2026-08-09 01:26:11 UTC - Model: anthropic / claude-opus-4-8

> Frameworks: MITRE EMB3D - MITRE ATT&CK for ICS - ISA/IEC 62443 (3-3, 4-2, 4-1, 2-1) - ISA-TR84.00.09 - Attify IoT. Identifiers marked * are model-supplied (not from the embedded reference set).

Executive Summary

SIMATIC PCS 7 is a distributed process control system (DCS) built from Windows-based Engineering Stations (SIMATIC Manager, CFC/SFC, HW Config, S7 Block Privacy, PDM), Operator System (WinCC) servers/clients, SIMATIC BATCH/Route Control/Maintenance servers and Process Historian, SIMATIC S7-400/S7-400H/S7-400FH controllers (AS), ET 200M/SP/iSP/pro remote I/O, and fieldbuses (PROFINET, PROFIBUS DP/PA, FOUNDATION Fieldbus, Modbus, HART, AS-i, Industrial Wireless LAN). The S7 controllers and the S7comm/S7comm-plus engineering protocol are the highest-value assets: they historically lack per-message authentication and encryption, allowing unauthorized program download (T0843), modify controller tasking (T0821), and change of operating mode (T0858) - mapped to EMB3D TID-406, TID-408, TID-407, and CR 3.1/3.4/1.2 gaps. The Windows-based ES/OS host layer inherits a large IT attack surface (malware, RDP/SMB, living-off-the-land T0205/T0807) and is the primary pivot into the OT zone; project files (T0873) and transient engineering laptops (T0864) are key infection vectors. The Safety Integrated (S7 F/FH, F-Systems, cause & effect matrix) safety-instrumented functions are configured from the SAME engineering toolchain as the BPCS, so a compromised ES can defeat BPCS/SIS independence (ISA-TR84 INDEP/DEMAND) and cause Loss of Safety (T0880). Weak/legacy TLS, cleartext OPC/S7 traffic, PDM web access to field devices, and remotely-initiated Management Console software rollouts expand the confidentiality and integrity exposure. Priority mitigations: cryptographically authenticated controller access and signed programs (MID-034/040/041, CR 1.2/3.4), strict zone/conduit segmentation with an independent SIS zone (TR84-SECZONE), hardened/patched Windows hosts with allowlisting (M0938/M0948), and secure engineering-workstation hygiene to break the ES->AS->SIS kill chain.

1. System Model

SIMATIC PCS 7 is a multi-level DCS. The plant/office bus (Industrial Ethernet) hosts Engineering Stations and OS/Batch/Route Control/Maintenance servers and Process Historian; the system/terminal bus connects OS clients. Controllers (SIMATIC S7-400 AS, incl. S7-400H high-availability and S7-400F/FH fail-safe) connect via PROFINET/Industrial Ethernet to servers and downstream to ET 200 remote I/O over PROFIBUS DP/PA and FOUNDATION Fieldbus H1, with HART/AS-i and Industrial Wireless LAN at the field level. Optional Web Server/OpenPCS 7/Information Server and MES/ERP integration bridge to the office/IT level through front/back firewalls.

Components

Component	Role	Sub-components
Engineering Station (ES)	System-wide engineering: SIMATIC Manager, HW Config, CFC/SFC, OS engineering, F-Systems safety engineering, PDM	SIMATIC Manager, CFC/SFC editor, HW Config, S7 Block Privacy, SIMATIC PDM, Advanced ES, Windows OS + SQL
Operator System (OS) Server/Client	HMI runtime, alarms, trends, archiving (WinCC based)	WinCC runtime, OS Client 427D, Web Client, Windows OS + SQL Server
SIMATIC BATCH / Route Control / Maintenance servers	Batch automation, material transport, asset/maintenance station	Batch server, Route Control server, Maintenance server
Process Historian / Information Server	Long-term process data archiving and reporting	Historian DB, Information Server (reporting)
PCS 7 Management Console	Central inventory and software/patch rollout to stations	Console, Management Console agents, file server for setups
Automation System (AS) controller	Process control logic execution	S7-400 CPU, S7-400H (redundant), S7-400F/FH (fail-safe/safety), CP communication processors, PCS 7 BOX / AS RTX embedded
Remote I/O (ET 200 family)	Distributed process I/O and signal conditioning	ET 200M, ET 200SP, ET 200iSP, ET 200pro, Ex-I/O / HART modules, SIMOCODE pro

Component	Role	Sub-components
Network infrastructure	Industrial Ethernet/fieldbus switching, coupling and firewalling	SCALANCE X switches, IE/PB link + DP/PA coupler, PA/FF link, Y-link, Front/Back Firewall
Safety system (Safety Integrated for Process Automation)	SIS logic solver and safety functions	S7 F/FH systems, F-Systems runtime, cause & effect matrix engineering, F-capable ET 200 fail-safe I/O

Interfaces

Interface	Type	Protocol	Exposure
Plant/Terminal bus	network	Industrial Ethernet, S7comm/S7comm-plus, OPC/OPC UA, WinCC	zone
Engineering download to AS	network	S7comm-plus (TCP/102)	zone
Controller fieldbus	bus	PROFINET IO	internal
Remote I/O bus	bus	PROFIBUS DP/PA	internal
Field device bus	bus	FOUNDATION Fieldbus H1, HART, AS-Interface	physical
Industrial Wireless LAN / WirelessHART	wireless	IEEE 802.11 IWLAN, WirelessHART	physical
MES/ERP & Web access	network	OpenPCS 7/OPC, HTTPS Web Server, Information Server	external
PDM field-device web access	api	HTTP/HTTPS to PDM server	zone
Management Console software rollout	network	Kerberos-authenticated agent channel	zone
CPU maintenance / MMC / display	physical	SIMATIC Micro Memory Card, front panel	physical
Serial / Modbus links	bus	Modbus, serial	internal

Data Flows

From	To	Data	Protocol	Crosses boundary
Engineering Station	Automation System (AS) controller	Control program (CFC/SFC blocks), HW config, mode changes	S7comm-plus/TCP 102	Yes
Engineering Station	Safety system (S7 F/FH)	Safety logic (cause & effect matrix), F-parameters	S7comm-plus/F-communication	Yes
Automation System (AS) controller	Operator System Server	Process values, alarms, status	S7comm/OPC	Yes
OS Server	OS/Web Clients	HMI graphics, alarms, operator commands	WinCC/HTTPS	Yes
AS controller	Remote I/O (ET 200)	I/O image, cyclic process data	PROFINET IO / PROFIBUS DP	Yes
Remote I/O	Field devices	Sensor/actuator signals, HART parameters	PROFIBUS PA / HART / FF H1	Yes
MES/ERP	OpenPCS 7 / Information Server	Production orders, KPIs, reports	OPC/HTTPS	Yes
Management Console	Management Console agents	Software packages, patches, inventory	Kerberos-authenticated channel	Yes

2. Device Model - EMB3D Properties

Property	Category	Feature / Interface	Present	Notes

Property	Category	Feature / Interface	Present	Notes
PID-11	Hardware	S7-400 CPU microprocessor; ET 200 module MCUs; Windows x86 hosts	Yes	Multiple processors across AS, I/O and IPC-based stations.
PID-12	Hardware	SIMATIC Micro Memory Card (MMC) / external flash and station HDD/SSD	Yes	Removable MMC stores CPU program/config; server disks store project & historian DB.
PID-14	Hardware	USB/serial on IPC stations; MMC slot; front-panel ports	Yes	Transient media (T0847) risk on ES/OS hosts and CPU MMC.
PID-15	Hardware	CPU/CP diagnostic and maintenance ports; IPC debug interfaces	Yes	Assumed present; physical diagnostic/test interfaces require protection (CR 2.13/EDR 2.13).
PID-21	System Software	S7-400 CPU firmware bootloader; IPC UEFI/BIOS	Yes	Boot integrity of controllers historically not signed on older CPUs.
PID-23	System Software	Windows OS on ES/OS/servers; RTOS/firmware on S7-400 & ET 200	Yes	Windows host layer dominates IT attack surface.
PID-232	System Software	Windows user/process separation; controller lacks OS-style users	Yes	Controller access relies on protection level/password, not per-user accounts.
PID-27	System Software	Firmware update for CPUs/CPs/ET 200; SUS software update; Management Console rollout	Yes	Remotely-initiated updates (PID-275) via Management Console.
PID-271	System Software	Legacy S7-400 firmware integrity	Yes	Older CPUs lacked cryptographic firmware validation; newer generations added signing.
PID-275	System Software	Management Console remote software/patch rollout to agents	Yes	Remote update can DoS or push malicious packages if console compromised (TID-217).
PID-28	System Software	WinCC/OS event logs, Windows event log, historian audit	Yes	Logs can be tampered on host (TID-225) or leak info (TID-226).
PID-31	Application Software	WinCC runtime, SIMATIC Manager, PDM, BATCH/Route Control applications	Yes	Large application surface on Windows.
PID-311	Application Software	PCS 7 Web Server, Web Client, Information Server, PDM web access	Yes	HTTP(S) management/reporting UIs - web app threats apply.
PID-321	Application Software	Program download from ES/IDE to controller (CFC/SFC compiled S7 blocks)	Yes	Core engineering capability; excessive trust in ES/IDE (TID-303).
PID-324	Application Software	Program upload/download from engineering workstation	Yes	Enables T0843 program download / T0845 upload.
PID-331	Application Software	S7 controller services accepting engineering commands	Yes	Historically unauthenticated S7 services on older CPUs.
PID-3321	Application Software	S7 CPU protection-level password; WinCC/OS user passwords	Yes	Password-based; strength/lockout dependent on configuration.
PID-41	Networking	S7comm/S7comm-plus, OPC/OPC UA, PROFINET, WinCC network services	Yes	Remote network services exposed across zones.

Property	Category	Feature / Interface	Present	Notes
PID-411	Networking	Engineering & parameterization services (program download, PDM config)	Yes	Sensitive config modification over network.
PID-4111	Networking	Legacy S7comm / PROFINET / PROFIBUS message authentication	Yes	Lack of per-message authentication on legacy protocols (TID-406/407).
PID-4112	Networking	Cleartext S7comm/OPC/PROFINET payloads	Yes	No encryption on legacy control traffic (TID-408).
PID-4113	Networking	TLS for OPC UA / Web / newer S7comm-plus	Yes	Crypto available on modern paths; legacy paths remain cleartext.
PID-42	Networking	IE/PB link, PA/FF link, Y-link, SCALANCE routing/coupling	Yes	Message forwarding/routing between Ethernet and fieldbus (TID-412).

3. EMB3D Threat -> Mitigation Table

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
S7comm/S7comm-plus controller engineering services	TID-406	Unauthorized Messages or Connections	High	High	MID-034, MID-018, MID-038, MID-083	Authenticate controller access, require auth for privileged engineering functions, ACL/firewall the engineering conduit.
S7comm/OPC/PROFINET traffic	TID-408	Unencrypted Sensitive Data Communication	High	High	MID-035, MID-081, MID-044	Encrypt control traffic (OPC UA/TLS, secure tunnels); use strong protocols on all conduits.
Legacy control protocols	TID-407	Missing Message Replay Protection	Medium	High	MID-036, MID-037, MID-034	Use nonces/timestamps and message authentication on control conduits.
Program download from ES to AS	TID-303	Excessive Trust in Offboard Management/IDE Software	High	High	MID-040, MID-041, MID-018	Cryptographically sign custom/vendor programs; authenticate the engineering source before accepting downloads.
S7-400 legacy firmware	TID-201	Inadequate Bootloader Protection and Verification	Medium	High	MID-002, MID-026, MID-029	Hardware-backed secure boot, signed firmware, hardware root of trust on newer controller generations.
CPU/CP firmware update path	TID-211	Device Allows Unauthenticated Firmware Installation	Medium	High	MID-026, MID-030, MID-002	Signed, authenticated firmware with rollback protection.
Management Console remote rollout	TID-217	Remotely Initiated Updates Can Cause DoS	Medium	High	MID-026, MID-018, MID-038	Authenticated, signed rollout packages; strong admin authentication for the console.
WinCC/Historian host OS	TID-205	Existing OS Tools Maliciously Used for Device Manipulation	High	High	MID-016, MID-014, MID-039	Least functionality, application allowlisting/sandboxing, restrict diagnostic tooling.
PCS 7 Web Server / PDM web / Information Server	TID-319	Cross Site Scripting (XSS)	Medium	Medium	MID-071, MID-074, MID-073	Sanitize/escape web input, CSRF tokens, secure session management.
WinCC / project databases	TID-320	SQL Injection	Medium	High	MID-072, MID-049, MID-027	Parameterized queries, secure credential storage, validated crypto libs.

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
WinCC/OS credentials	TID-311	Default Credentials	Medium	High	MID-043, MID-049, MID-046	Manage/remove default credentials, secure password storage, lockouts.
Engineering project files	TID-301	Applications Binaries Modified	Medium	High	MID-042, MID-009, MID-040	Integrity checking of project/binaries, consistency checks, signed programs.
PROFINET/S7 network stack	TID-405	Network Stack Resource Exhaustion	Medium	High	MID-080, MID-032, MID-083	Request processing limits, service availability manager, firewall/ACL.
IE/PB link, PA/FF link, Y-link, SCALANCE	TID-412	Network Routing Capability Abuse	Medium	High	MID-083, MID-035, MID-034	Segment and ACL conduits, encrypt/authenticate cross-boundary traffic.
Host/OS audit logs	TID-225	Logs can be manipulated on the device	Medium	Medium	MID-017, MID-085, MID-084	Security auditing, export logs off-device, restrict sensitive data in logs.

4. MITRE ATT&CK for ICS

Tactic	Technique ID	Technique	Applicability	Related EMB3D
Initial Access	T0864	Transient Cyber Asset	Engineering laptop / PDM mobile workstation moving in/out of OT introduces malware and connects to ES/AS.	TID-303, TID-205
Initial Access	T0865	Spearphishing Attachment	Windows ES/OS operators phished to gain foothold on plant/terminal bus.	TID-205
Initial Access	T0822	External Remote Services	Vendor/remote access (RDP/VPN) and Web Server/OpenPCS 7 bridging IT-OT provide entry.	TID-310, TID-408
Execution	T0843	Program Download	ES downloads CFC/SFC logic to S7-400 AS; attacker replicates to alter control.	TID-406, TID-303
Execution	T0807	Command-Line Interface	PowerShell/cmd on WinCC/ES hosts to run tooling and scripts.	TID-205
Persistence	T0873	Project File Infection	Infect SIMATIC Manager/CFC project files so malicious logic re-downloads on next engineering cycle.	TID-301
Persistence	T0839	Module Firmware	Implant firmware in CPU/CP/ET 200 modules on legacy devices lacking signed firmware.	TID-201, TID-211
Privilege Escalation	T0890	Exploitation for Privilege Escalation	Exploit Windows/WinCC/PDM flaws to gain admin on host layer.	TID-219, TID-320
Evasion	T0856	Spoof Reporting Message	Send falsified process values/telemetry to OS to mask manipulation.	TID-407, TID-408
Discovery	T0846	Remote System Discovery	Enumerate S7 CPUs, CPs, ET 200 and SCALANCE on Industrial Ethernet.	TID-401, TID-406
Discovery	T0888	Remote System Information Discovery	Query CPU type/firmware/config; PDM reveals field-device inventory.	TID-401
Lateral Movement	T0859	Valid Accounts	Use WinCC/domain/default accounts to move ES->OS->AS.	TID-311, TID-303
Lateral Movement	T0867	Lateral Tool Transfer	Move tooling across plant bus via SMB/Management Console rollout.	TID-217
Collection	T0845	Program Upload	Upload S7 control logic to analyze/clone the process.	TID-303
Command and Control	T0869	Standard Application Layer Protocol	Blend C2 into OPC/HTTPS/S7 traffic across IT-OT boundary.	TID-408

Tactic	Technique ID	Technique	Applicability	Related EMB3D
Inhibit Response Function	T0878	Alarm Suppression	Modify WinCC alarm handling/thresholds to hide unsafe conditions.	TID-225
Impair Process Control	T0836	Modify Parameter	Change setpoints/CFC parameters in AS to drive process off-spec.	TID-406, TID-836
Impair Process Control	T0858	Change Operating Mode	Switch CPU to STOP/program mode to enable logic changes or halt control.	TID-406
Impact	T0880	Loss of Safety	Manipulate/defeat S7 F/FH SIS configured from shared ES, defeating BPCS/SIS independence.	TID-303, TID-201
Impact	T0879	Damage to Property	Brute-force/manipulate I/O to damage equipment.	TID-406, TID-407

5. Attify IoT Reverse-Engineering / Attack Surface

Domain	Vector	Technique	Finding / Hypothesis	Related EMB3D
Hardware	Debug/test interface discovery on IPC & CPU	UART/JTAG probing on ES/OS Industrial Workstations and CPU maintenance ports	Physical diagnostic/test interfaces likely present; unprotected access could dump memory/config (assumption).	TID-115, TID-119
Hardware	Removable media / MMC & USB	Extract SIMATIC Micro Memory Card; USB autorun on Windows hosts	CPU program/config on MMC and transient USB media are classic infection/extraction paths.	TID-108, TID-111
Firmware	CPU/CP firmware acquisition & analysis	Obtain vendor firmware update files; check signing/rollback	Legacy S7-400 firmware lacked cryptographic validation; assess per generation.	TID-201, TID-211, TID-216
Firmware	Secret & credential hunting in project/host images	Entropy/grep of WinCC/PDM binaries and project DBs for hardcoded creds/keys	WinCC/SQL default/hardcoded DB credentials historically documented.	TID-328, TID-329, TID-311
Network	ICS/OT protocol testing	S7comm/S7comm-plus, PROFINET, OPC probing; unauthorized command & fuzzing	Legacy S7 services accept unauthenticated engineering commands; fuzzing can DoS stack.	TID-406, TID-405, TID-401
Network	Cleartext & MitM on control conduits	Capture S7/OPC/PROFINET; ARP redirect; replay commands	Cleartext control traffic enables sniffing and replay of setpoints/commands.	TID-408, TID-407
Network	Remote access services review	RDP/VNC/SSH exposure and default-credential check on ES/OS	Remote services and vendor access widen IT-OT exposure.	TID-310, TID-311
Application	Management web UI testing	Auth bypass, XSS/CSRF/SQLi on PCS 7 Web Server, PDM web, Information Server	Web management/reporting endpoints are candidate injection/session targets.	TID-319, TID-320, TID-322
Radio	IWLAN / WirelessHART	Key capture, deauth/rogue AP, replay on Industrial Wireless LAN and WirelessHART	Wireless field/operator links extend attack surface if keys/segmentation weak.	TID-408, TID-407, TID-411

6. ISA/IEC 62443 Requirements Mapping

6.1 62443-4-2 Component Requirements

Req ID	Name	Design Mitigation	Addresses
CR 1.2	Software process and device identification and authentication	Require mutual authentication for engineering connections to S7 controllers (S7comm-plus with access protection) on all interfaces incl. maintenance.	TID-406, TID-303
CR 1.5	Authenticator management	Eliminate default/hardcoded WinCC/SQL and controller credentials; enforce secure authenticator lifecycle.	TID-311, TID-328
CR 2.1	Authorization enforcement	Enforce least-privilege RBAC across ES/OS functions and controller protection levels.	TID-303, TID-205
CR 2.13 / EDR 2.13	Use of physical diagnostic and test interfaces	Disable/protect CPU maintenance and IPC debug ports; control MMC access.	TID-115, TID-119, TID-108
CR 3.1	Communication integrity	Protect integrity of control/engineering traffic (authenticated S7comm-plus, OPC UA signing).	TID-407, TID-408
CR 3.4	Software and information integrity	Verify authenticity/integrity of downloaded programs and project files (signed programs, consistency checks).	TID-301, TID-303
CR 3.5	Input validation	Validate protocol/web inputs to WinCC, PDM, Web Server to prevent injection and malformed-packet DoS.	TID-319, TID-320, TID-405
CR 3.10 / EDR 3.10	Support for updates	Authenticated, signed firmware and software updates with rollback protection for CPUs/CPs/ET 200 and Management Console packages.	TID-211, TID-216, TID-217
EDR 3.14	Integrity of the boot process	Secure/verified boot with hardware root of trust on controller generations that support it.	TID-201
CR 4.1	Information confidentiality	Encrypt control/engineering data at rest and in transit; protect keys and project secrets.	TID-408, TID-329
CR 7.1	Denial of service protection	Maintain essential control functions under crafted-traffic load; rate-limit stacks.	TID-405
CR 7.7	Least functionality	Disable unused ports/services/web endpoints on ES/OS/controllers.	TID-205, TID-310

6.2 62443-3-3 System Requirements

Req ID	Name	System Control
SR 1.1	Human user identification and authentication	Central AD-based identity for ES/OS/servers; per-user accounts, no shared operator logins.
SR 1.2	Software process and device identification and authentication	Authenticate servers, agents and controllers on the plant/terminal bus; Kerberos for Management Console.
SR 2.1	Authorization enforcement	Least-privilege roles for engineering vs operation; restrict who can download to AS/SIS.
SR 3.1	Communication integrity	Integrity-protected conduits between ES?AS, OS?AS, and cross-firewall flows.
SR 3.4	Software and information integrity	Detect unauthorized changes to project files, controller logic and OS images.
SR 5.1	Network segmentation	Segment ES/OS zone, control zone, SIS zone and IT/MES with front/back firewalls.
SR 5.2	Zone boundary protection	Deny-by-default conduits; restrict S7/OPC to required endpoints only.
SR 6.2	Continuous monitoring	Deploy OT IDS/anomaly detection for S7comm and PROFINET; centralize logs.
SR 7.3	Control system backup	Backup projects, WinCC, historian and controller configs.
SR 7.7	Least functionality	Harden Windows hosts; disable unused services and removable media.

6.3 62443-4-1 Secure Development Lifecycle

Practice	Name	Recommendation
SR-2	Product threat model	Maintain a PCS 7 component/system threat model covering S7comm-plus, WinCC, PDM and update paths.
SD	Secure by design	Default-deny controller access, attack-surface reduction, authenticated engineering by default.
SI	Secure implementation	Secure coding for WinCC/PDM/web components; parameterized SQL, output encoding.
SVV	Security verification & validation testing	Fuzz S7comm/PROFINET/OPC and web endpoints; pen-test ES->AS->SIS paths.
DM	Management of security-related issues	Coordinate with Siemens ProductCERT advisories; triage CVEs for CPU/WinCC/PDM.
SUM	Security update management	Qualify and deliver signed updates via SUS/Management Console with rollback control.
SG	Security guidelines	Follow Siemens PCS 7 security concept/hardening & operational deployment guidance.

7. ISA-TR84.00.09 Safety / Hazard / Consequence

Applicable: Yes - SIS/SIF: PCS 7 includes Safety Integrated for Process Automation: S7 F/FH fail-safe controllers, F-Systems runtime, and fail-safe ET 200 I/O implementing Safety Instrumented Functions (e.g., emergency shutdown, high-pressure/temperature trip) at defined SIL. Critically, the SIS is engineered from the SAME ES toolchain (SIMATIC Manager, cause & effect matrix) as the BPCS, and can share Industrial Ethernet infrastructure - creating cyber pathways that can defeat BPCS/SIS independence (TR84-INDEP).

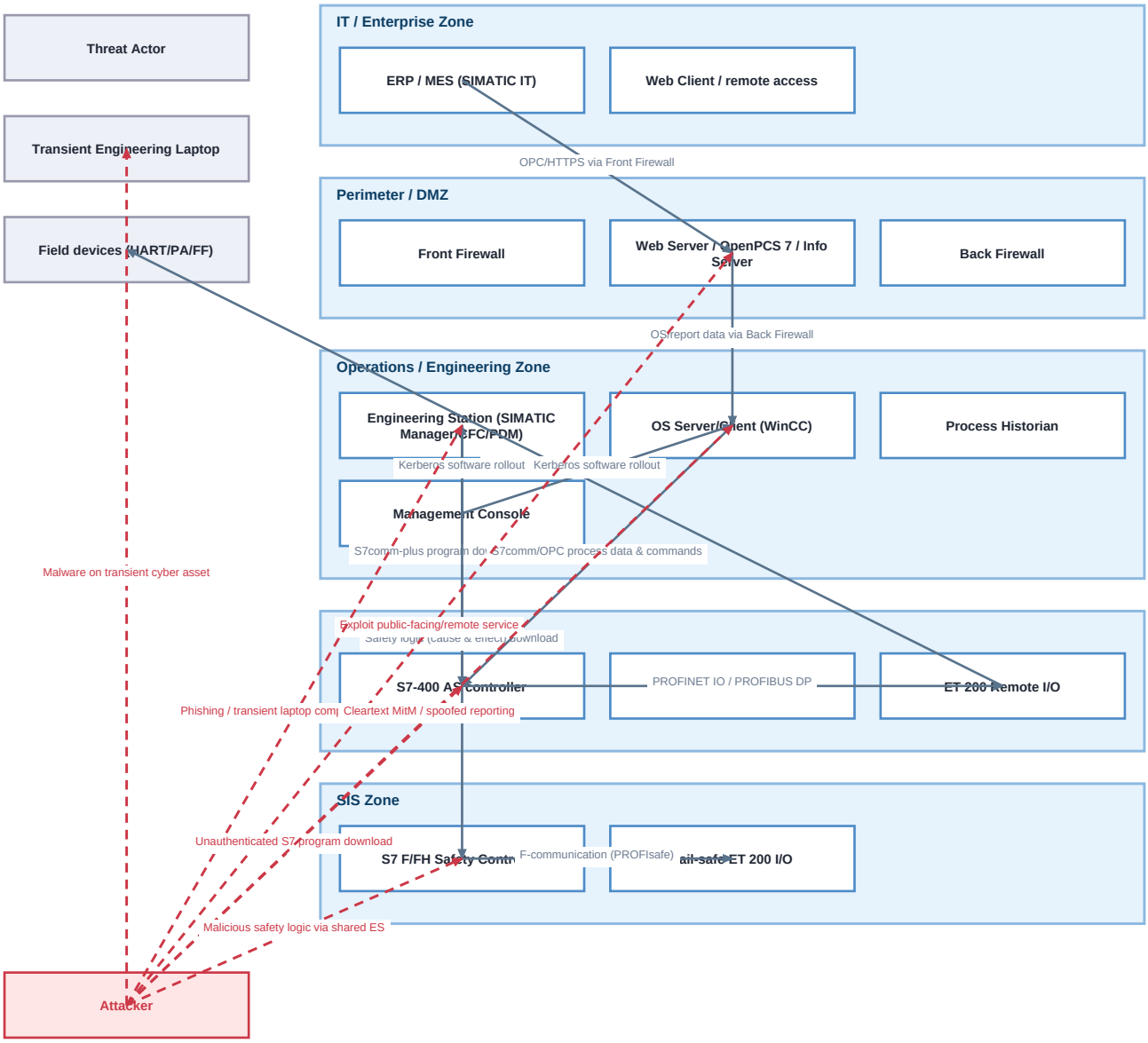
Scenario	Attack Path	Consequence	Severity	Defeats IPLs	Countermeasures
Attacker compromises Engineering Station and pushes malicious/altered safety logic (cause & effect matrix) to S7 F/FH, disabling a trip.	T0864/T0865 -> ES compromise (TID-303) -> T0843 program download to F-CPU (TID-406) -> T0821 modify controller tasking -> T0880 Loss of Safety	SIF fails to bring process to safe state on demand (e.g., overpressure not tripped) leading to loss of containment/explosion.	Catastrophic	Yes	Independent SIS security zone (TR84-SECZONE); signed/authenticated safety programs (MID-040/041, CR 3.4); separate engineering credentials & workflow for SIS; MoC for security (TR84-MOC); hard-wired final trip layer independent of BPCS.
Alarm suppression / spoofed process view masks an approaching unsafe condition, delaying operator response while a demand builds on the SIF.	OS host compromise (TID-205) -> T0878 Alarm Suppression / T0856 Spoof Reporting (TID-225/408) -> T0836 Modify Parameter (TID-406)	Operator loses view of true state; abnormal deviation creates a demand while independent protection is simultaneously undermined (TR84-DEMAND).	Major	Yes	Off-device tamper-evident logging (MID-085); alarm integrity monitoring (SR 6.2); independent SIS alarms not routed through BPCS OS.
Legacy fieldbus command replay/manipulation drives a final element to an unsafe position while BPCS shows normal.	Fieldbus MitM (TID-407/408) -> T0855 Unauthorized Command Message -> T0831 Manipulation of Control -> T0879 Damage to Property	Valve/actuator forced to unsafe state; equipment damage or release.	Serious	No	Authenticate/encrypt control conduits where supported (MID-034/035); segment field networks; physical/mechanical protection layers (M0805).

8. Risk Register

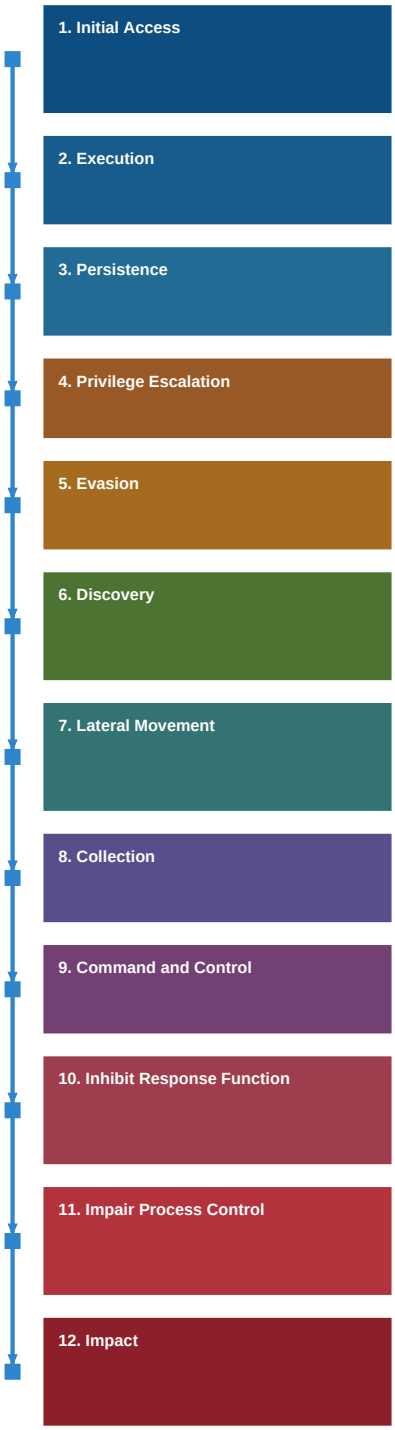
ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements

ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements
R1	Unauthenticated/insufficiently authenticated program download and mode change to S7-400 AS via S7comm allows attacker to alter or halt control logic.	TID-406, TID-303, TID-407	T0843, T0858, T0836	H	H	Critical	Enforce controller access protection/authenticated S7comm-plus, sign programs, deny-by-default engineering conduit ACLs.	CR 1.2, CR 3.4, SR 5.2
R2	Compromise of a shared Engineering Station lets attacker reconfigure both BPCS and S7 F/FH SIS, defeating independence and causing Loss of Safety.	TID-303, TID-201	T0864, T0843, T0880	M	H	Critical	Independent SIS security zone, separate SIS engineering credentials/workflow, signed safety programs, MoC for security.	CR 3.4, SR 5.1, EDR 3.14
R3	Windows ES/OS/WinCC host compromise (phishing, transient assets, LOLbins, SQLi, default DB creds) provides pivot into OT and control of HMI.	TID-205, TID-320, TID-311	T0865, T0807, T0859	H	H	Critical	Patch/harden hosts, application allowlisting, remove default credentials, parameterized SQL, restrict remote services.	CR 1.5, CR 7.7, SR 7.7
R4	Cleartext control/engineering traffic enables sniffing, MitM and replay of setpoints/commands across zones.	TID-408, TID-407, TID-412	T0830, T0856, T0855	M	H	High	Encrypt/authenticate conduits (OPC UA/TLS, secure tunnels), segment and ACL fieldbus couplers.	CR 3.1, CR 4.1, SR 3.1
R5	Management Console remote software/patch rollout abused to distribute malicious packages or DoS stations plant-wide.	TID-217, TID-303	T0867, T0816	M	H	High	Signed rollout packages, strong console admin auth/MFA, restricted agent conduits, change control.	CR 3.10, CR 2.1, SR 1.2
R6	Project file infection persists malicious logic that re-downloads to controllers on the next engineering cycle.	TID-301	T0873, T0843	M	H	High	Integrity/consistency checks of project files and blocks, code signing, restricted file permissions, off-device backups.	CR 3.4, SR 3.4, SR 7.3
R7	Crafted PROFINET/S7 traffic exhausts controller/CP network stacks causing denial of control and view.	TID-405	T0814, T0813	M	H	High	Rate-limiting, network request processing limits, OT IDS, redundant AS (S7-400H).	CR 7.1, CR 7.2, SR 7.1
R8	Web management/reporting endpoints (Web Server, PDM web, Information Server) vulnerable to XSS/CSRF/SQLi and session hijack.	TID-319, TID-320, TID-322	T0819, T0890	M	M	Medium	Input sanitization/output encoding, CSRF tokens, secure session mgmt, patching.	CR 3.5, CR 3.7, SR 3.5
R9	Legacy controller firmware lacks signing, allowing malicious module firmware implant for persistence.	TID-201, TID-211, TID-216	T0839, T0857	L	H	High	Use CPU generations with secure boot/signed firmware, rollback protection, verify firmware provenance.	EDR 3.14, CR 3.10, EDR 3.10

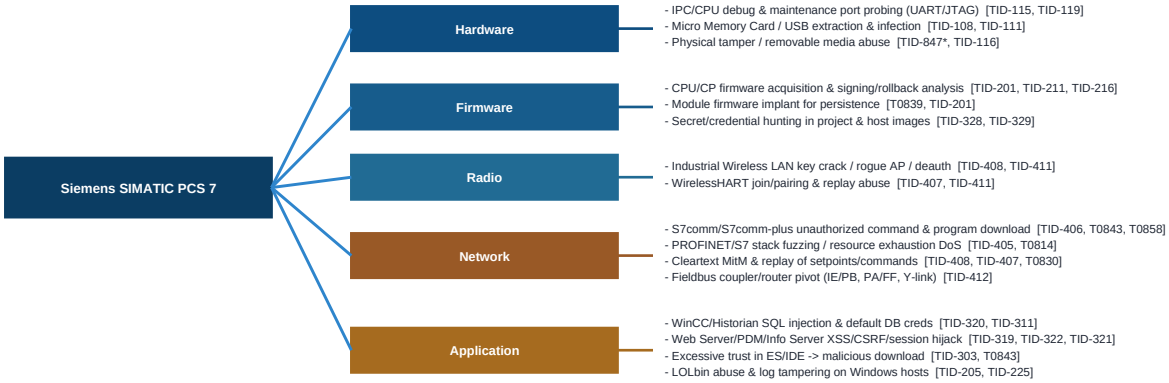
9. Threat Model Diagram



10. ICS Cyber Kill Chain



11. Attack Mind Map



Assumptions

- Exact PCS 7 version and S7 CPU generation are unspecified; some controllers may be legacy (no signed firmware/authenticated S7comm) while newer S7-410/S7-1500-based AS support access protection and signing.
- The brochure does not enumerate physical debug/JTAG/UART ports on IPC or CPU hardware; their presence and protection are assumed and should be verified.
- WinCC/Historian use Microsoft SQL Server; default/hardcoded DB credential exposure is assumed based on historical advisories and must be validated against the deployed version.
- Front/back firewall architecture exists per the brochure but concrete zone/conduit rules were not requested and are not modeled here.
- Safety Integrated (S7 F/FH, F-Systems) is deployed for at least one SIF; if no SIS is present, ISA-84 scenarios should be re-scoped.
- Industrial Wireless LAN / WirelessHART may or may not be deployed depending on the plant; radio surface treated as conditional.